

文件上传漏洞报告

测试目标: Flask头像上传功能 | 漏洞位置: POST /upload | 报告日期:
2026-07-09

一、漏洞概述

用户头像上传功能对上传文件未做任何校验，存在三个高危漏洞：路径穿越、任意文件上传、持久化XSS。

漏洞代码：

```
file.save(os.path.join(upload_dir, file.filename))
```

二、漏洞详情

漏洞1：路径穿越（目录遍历）

测试方法：

```
curl -F "file=@test.txt;filename=../../evil.txt"  
http://.../upload
```

结果：文件名中的 `../../` 未被过滤，文件逃逸出 uploads 目录。

原目标路径	实际保存路径
static/uploads/evil.txt	process/evil.txt

风险：攻击者可覆盖系统任意文件（如 `/etc/crontab`、`/etc/passwd`）。

漏洞2：任意文件上传

测试payload：

文件类型	能否上传
xss.html (含脚本)	能
shell.php	能
test.py	能
evil.js	能
无扩展名文件	能

风险：攻击者可上传任意恶意文件到服务器。

漏洞3：持久化XSS

测试方法：

上传含 script 标签的HTML文件 → 直接访问URL即执行

结果：上传的 HTML 文件中的 JavaScript 在浏览器中直接执行。

风险：攻击者可上传钓鱼页面，诱导其他用户访问窃取信息。

三、修复方案

修复1：路径穿越

```
filename = os.path.basename(file.filename)
save_path = os.path.normpath(os.path.join(upload_dir,
filename))
if not save_path.startswith(os.path.normpath(upload_dir)):
    return render_template("upload.html", error="非法的文件
路径")
```

修复2：类型白名单

```
allowed_extensions = {".jpg", ".jpeg", ".png", ".gif",
".webp", ".bmp"}
ext = os.path.splitext(filename)[1].lower()
if ext not in allowed_extensions:
```

```
return render_template("upload.html", error="不支持的文件类型")
```

修复3：XSS 防御

通过限制仅允许图片类型上传，从源头阻断 HTML/JS 文件的上传。

四、修复验证

测试项	修复前	修复后
../.././evil.txt 路径穿越	逃逸成功	已拦截
.html 文件上传	成功	已拦截
.php 文件上传	成功	已拦截
.png 正常图片上传	正常	正常

五、结论

三个高危漏洞均源于对用户上传文件未做任何校验。通过文件名过滤、扩展名白名单、路径安全检查三项修复，已从源头阻断攻击。